# Security Now! #1051 - 10-11-25

## Amazon sues Perplexity

### This week on Security Now!

• FFmpeg teaching assembly language for performance. • The state of Nevada recovers after not paying ransom. • A "rounding error" nets a clever attacker $128 million. • Why would Chrome decide to start form-filling driver's licenses? • The UK's six major telecom providers to block number spoofing. • XSLT support being removed from browsers. Will anyone notice?
• Firefox introduced paid support options for organizations. • Russia continues to fight against non-Russian Internet. • Google acquires another Internet security company (Wiz). • The EU to finally fix their cookie permission mistake. • More countries drop Microsoft office for open choices. • More countries question and examine Chinese made buses. • Microsoft discovers some information leakage from LLMs. • What does Amazon's lawsuit against Perplexity's agents mean for next-generation browsers?

An important consideration when you're able to decide where you should have your emergency:

# Security News

**Assembly Language Lives!**
Last Wednesday the 5th, the official FFmpeg 'X' account tweeted:

People who posted in the thread that followed questioned that a 10 to 50x speed improvement could possibly arise from coding in assembly versus an efficient high-level language. Much as I love assembly and choose it for all of my own work, I agree. What I suspect must be going on is a very unfair comparison. All modern processor instruction sets have extremely powerful and fast specialized vector and array-handling streaming instructions which are heavily pipelined which can be used if the entire solution is deliberately designed to use them. Any solution that did not use them would be massively handicapped by comparison.

So any naive implementation which accomplished the same function written in a high level language that did not also take advantage of the processor architecture's powerful acceleration features would run far more slowly. But not due to inefficiencies in the high-level code, but because apples were being compared to oranges. And, in fact, in any scenario where most of the work is being done by a few hyper-powerful machine-level instructions that could just as easily be invoked from that higher-level language, any difference between the high-level language and assembly would largely be lost – since neither of the languages are doing any of the real work – they're both just asking the processor to do the work for them.

I wanted to share this 'X' posting from the FFmpeg group because those tutorials posted over on Github, in English, French and Spanish might be of interest to anyone who is curious about assembly language. Since our listeners know that assembly language is my preference, I'm often asked how to get started: https://github.com/FFmpeg/asm-lessons. They also offer a Discord server for asking and receiving answers to questions.

**Nevada brags about not paying**

Last May, an employee with the State of Nevada made the mistake of clicking on a malicious search engine ad which installed a malicious sysadmin tool from a spoofed website. Three months later Nevada received ransomware demands which it declined. Having finally recovered in full, last Wednesday the state's press release carried the headline *"Nevada completes 28-day recovery from statewide cyber incident; refuses ransom and releases After-Action Report"* It said:

*CARSON CITY, NV – November 05, 2025 – The Governor's Technology Office (GTO) today released the 2025 Statewide Cyber Incident After-Action Report, detailing Nevada's 28-day recovery from an August ransomware attack. Guided by pre-established incident playbooks and vendor agreements, the State did not pay a ransom, restored statewide services within four weeks, and recovered approximately 90% of impacted data. The remaining items, while still in control of the State, were not required for service restoration and are undergoing risk-based review with continued monitoring; the State will take appropriate notification or remediation actions if new information emerges.*

*Governor Joe Lombardo said: "Nevada's teams protected core services, paid our employees on time, and recovered quickly—without paying criminals. This is what disciplined planning, talented public servants, and strong partnerships deliver for Nevadans."*

*State CIO Timothy D. Galluzi said: "We executed, then communicated. Our staff and agency partners worked around the clock with expert vendors to contain the threat, rebuild securely, and bring services back online in measured phases." The numbers are:*

- *28 days to full service restoration across affected platforms*
- *~90% of impacted data recovered; residual items under risk-based review with enhanced monitoring*
- *No ransom paid; response executed under cyber insurance and pre-negotiated vendor agreements*
- *4,212 overtime hours by 50 State employees, at $210,599.87 direct OT wages (fully-loaded est. $259,037.84)*
- *$1,314,200 obligated to specialized partners (forensics, recovery, legal, engineering) to accelerate containment and rebuild.*

*How Nevada stepped up*

- *Continuity of operations: Payroll processed on schedule; high-impact public safety and citizen-facing systems were restored in phased order.*
- *Speed and discipline: Around-the-clock State teams executed 24×7 playbooks alongside partners, enabling a 28-day full restoration—faster than many public-sector timelines for incidents of similar scope.*
- *Fiscal responsibility: Surge work was led by State staff. Even using conservative fully-loaded OT costs, the State avoided hundreds of thousands of dollars versus an all-contractor model—while retaining institutional knowledge and tighter change control.*

*Within hours, Nevada engaged pre-positioned experts for forensics, recovery, and legal/privacy support—including Mandiant, Microsoft DART, Dell, SHI/Palo Alto, BakerHostetler, and local engineering support from Aeris—under cyber-insurance and statewide contracts.*

*The complete after-action report outlines next-phase hardening and modernization, including the pursuit of a centrally managed Security Operations Center (SOC), unified Endpoint Detection & Response (EDR), identity hardening, OS and application control, and expanded workforce training to sustain resilience against evolving threats.*

They're seeming rather pleased with themselves. I was unable to find any indication of the size of the ransom demand they declined. But given the reporting of the event at the end of August, I'd imagine that the demand was hefty. The Associated Press' headline was *"Cyberattack shuts down Nevada state offices and websites, governor's office says"* and Reuters headline was *"Nevada state offices close after wide-ranging 'network security incident'"*.

The most interesting data comes from their complete 30-page After Action Report. Among what we learn is:

*On August 24, 2025, at 01:50 AM PDT, the State of Nevada's Governor's Technology Office (GTO) identified a system outage that resulted in multiple virtual machines (VMs) going offline.*

*Initially locked out of the systems, the GTO team successfully regained access using backup credentials and discovered encrypted files alongside a ransom note. They isolated the affected VMs to prevent further spread of the ransomware. Legal counsel from BakerHostetler LLP was engaged and promptly brought in Mandiant, a leading cybersecurity firm under Google Cloud, to conduct a privileged forensic investigation.*

*The investigation revealed that the threat actor had infiltrated the system as early as May 14, 2025, when a state employee unknowingly downloaded a malware-laced system administration tool from a spoofed website. This tool installed a hidden backdoor, which remained active despite Symantec Endpoint Protection quarantining the tool on June 26. The attacker escalated their access by installing a commercial remote monitoring software, on multiple systems, compromising both standard and privileged user accounts.*

*By mid-August, the attacker had established encrypted tunnels and used Remote Desktop Protocol (RDP) to move laterally across critical systems, accessing sensitive directories including the password vault server. On August 24, the attacker deleted backup volumes and deployed ransomware, encrypting VMs and disrupting critical services.*

Elsewhere the report adds:

*Between August 16 and August 24, the threat actor accessed multiple critical servers, including the password vault server, and retrieved credentials from 26 accounts. They meticulously cleared event logs to obscure their activities. On the day of the ransomware deployment, the attacker deleted backup volumes and altered security settings to facilitate the execution of unauthorized code. At 01:30 AM PDT, ransomware was deployed, encrypting VMs and disrupting critical services.*

Not surprisingly, August 24th was a Sunday. So, very deliberately, at 1:30 AM on a Sunday, the attackers uncloaked and attacked. They relied upon no one being around and minimal if any crew even later in the morning on a Sunday to enable their active attack to go unnoticed for as long as possible.

This report pats themselves on the back frequently and I've removed most of that since it's not informative and it's somewhat nauseating. But in all fairness, Nevada's IT response was very impressive. On that Sunday Morning at 1:52am, the VMs were encrypted and went offline, crippling systems.

By 7:37am – on that same Sunday morning the incident had been escalated to the CIO and Governor's office.

Only a little over two hours later, by 9:51am the credential lockout was lifted using backup credentials and access to the internal systems was obtained. Encrypted files and the ransom note was discovered.

Two and a half hours after that by 12:37 in the early Sunday afternoon the affected VMs had been isolated to prevent further malware spread.

Four hours later, by 4:44pm, Nevada's legal counsel was added and they added Google's Mandiant forensic group.

And 15 minutes later at 5:03pm on that same Sunday, recovery protocols were initiated and post-attack recovery had started. State government employees took an unplanned two-day vacation the following Monday and Tuesday, by which time systems were beginning to come back up.

So we're talking about a full rallying response by dinnertime of the day it happened. The full recovery did take four weeks. It seems as though that might have been faster. But Nevada is fully back up and online and probably showed their cybersecurity firm that they were worth insuring. Overall, I'd say that's quite an impressive recovery.

**Balancer's expensive rounding error**

Last week, Check Point Research published an incident report describing an arcane attack on a DeFi – a Decentralized Finance – platform called Balancer. I'm not going to expend any effort in understanding the details of this, and my strongest advice would be for you not to, either. After you hear it I imagine you'll agree. But what happened here is still so very cool, even if it's nearly incomprehensible, that I wanted to share it. Check Point titled their report: *"How an Attacker Drained $128 Million from **Balancer** Through Rounding Error Exploitation"*. That's right. Apparently, some hackers **did** understand this and they literally leveraged the crap out of it.

Check Point wrote:

> *On November 3, 2025, Check Point Research's blockchain monitoring systems detected a sophisticated exploit targeting Balancer V2's ComposableStablePool contracts. The attacker exploited arithmetic precision loss in pool invariant calculations to drain $128.64 million across six blockchain networks in under 30 minutes.*
>
> *The attack leveraged a rounding error vulnerability in the _upscaleArray function that, when combined with carefully crafted batchSwap operations, allowed the attacker to artificially suppress BPT (Balancer Pool Token) prices and extract value through repeated arbitrage cycles. The exploitation occurred primarily during attacker smart contract deployment, with the constructor executing 65 micro-swaps that compounded precision loss to devastating effect.*

Okay. That was the overview.

*Balancer V2 uses a centralized "Vault" contract that holds all tokens across all pools, separating token storage from pool logic to reduce gas costs and enable capital efficiency. This shared liquidity design meant a single vulnerability in pool math could affect all ComposableStablePools simultaneously—which is exactly what happened in this attack.*

*Balancer V2's Internal Balance system allows users to deposit tokens once and use them across multiple operations without repeated ERC20 transfers. This system became critical to the attack. The exploit contract accumulated stolen funds in its internal balance during deployment, then withdrew them to the final recipient address in subsequent transactions.*

*ComposableStablePools use Curve's StableSwap invariant formula to maintain price stability between similar assets. The invariant D represents total pool value, and BPT price is calculated as D divided by totalSupply. However, the scaling operations that prepare balances for invariant calculations introduce rounding errors.*

*The mulDown function performs integer division that rounds down. When balances are small (8-9 wei ("way") range), this rounding creates significant relative errors—up to 10% precision loss per operation.*

The term Wei is important. A Wei, spelled Wei, is the smallest possible unit of Ethereum. One Ethereum, one ETH is 10^18 Wei. So, one Wei is far less than one trillionth of a cent. So some super clever individual realized that by using these incredibly small balances, the rounding error, which would normally be utterly insignificant, would result in up to a 10% precision loss per operation. Check Point then finishes their explanation writing:

*This precision error propagates to the invariant D calculation, causing abnormal reduction in the calculated value. Since BPT price equals D divided by total supply, the reduced D directly lowers BPT price, creating arbitrage opportunities for the attacker.*

*Individual swaps produce negligible precision loss, but within a single batchSwap transaction containing 65 operations, these losses compound dramatically. The lack of invariant change validation allowed the attacker to systematically suppress BPT price through accumulated precision errors, extracting millions in value per pool.*

I'm not sure that I would call this an attack at all. I mean, an extremely clever bad guy understood enough of the inner workings of this system to design an exploit of its inherent rounding error. He clearly started with a purely theoretical concept and made it work.
And for his trouble he's now slightly more than $128 million richer. I'm not completely certain that he didn't earn it. What I am certain of is that none of my money, nor any money belonging to anyone I care about is ever going to get anywhere near any of that wacky arcane technology. It all gives me the heebie-jeebies. So no thank you. I suppose I'm old fashioned, but I want to understand where I put my money.

**Chrome to fill in passport, driver's license, vehicle information and more**
A little burb from Google about a new feature in Chrome caught my eye, and not in a good way. Get a load of this. Google wrote:

*Chrome now helps you fill in passport, driver's license, vehicle information and more.*

*Chrome already saves you time every day by securely filling in your addresses, passwords and payment information. Today, we're making it even more helpful. For desktop users with enhanced autofill enabled, Chrome can now also fill in your passport and driver's license number, vehicle info (like license plate or VIN) and more. It can also better understand complex forms and varied formatting requirements, improving accuracy across the web.*

*We've designed enhanced autofill to be private and secure. When you enter relevant info into a form, Chrome will save this data only with your permission and protect it through encryption. And before filling in saved info on your behalf, Chrome will ask you to confirm, keeping you in full control of your data.*

*Starting today, these updates are available globally in all languages, and we plan to support even more data types over the coming months.*

Their little sample screen shot shows a form being filled-in with fields for *"Driver's License Number"* and *"Issuing State"*. Huh. Gee, we've all gotten along so well until now without that. How often do we see website asking us to provide them with our state issued identification such as a driver's license and the issuing state. It does kinda make you wonder why the Chrome devs might all of a sudden be thinking that making government identification data easier to fill out for websites might suddenly be useful and convenient when it has never come up before. Hmm. Anyone around here have any sudden need to prove who and how old they are?

There's one other thing about this. Recall that Google wrote: *"We've designed enhanced autofill to be private and secure. When you enter relevant info into a form, Chrome will save this data only with your permission and protect it through encryption. And before filling in saved info on your behalf, Chrome will ask you to confirm, keeping you in full control of your data."*

And there's no doubt they mean it. Even if the application for this information may be a concern, there's no doubt that Google will do their best to keep that data from leaking. The problem is, that's what data does. It leaks. Chrome is a good browser with excellent security. But it's still being constantly exploited and receiving patches to close 0-day vulnerabilities that have been discovered being used in the wild. This is not any criticism of Chrome and its Chromium engine. Firefox and Safari are in the same boat. Today's web browsers have grown so complex, and are also never being left alone, constantly needing to be updated with the latest features, that they can probably never become completely impervious.

To me, it's a convenience for my password manager to be able to fill out my credit card number and mailing/delivery address information. That often comes in handy. But I memorized my California driver's license number 54 years ago and aside from adding a '0' in front of its most significant digit when they ran out of numbers, it has never changed. So I've had no problem entering it the, perhaps, five or six times I've ever needed to provide my identity online, such as when I froze my credit reporting at the various agencies or when I signed up for social security.

But consider this: We're entering a very different universe if the world's most popular web browser designers, for some reason believe, that in the future we're going to be needing to provide our government identification information with sufficient regularity that enabling our web browser to do that for us will be a benefit.

And here's the other problem. Even if we trust Google to have done everything right about keeping that personally identifiable information secure and to never leak, how can we possibly trust all of the many individual websites that are, presumably, all going to be asking for this

information often enough for Google to have added this feature to Chrome? We all know that websites cannot keep secrets. They don't. Just ask Troy Hunt's Have I Been Pwned. And don't forget that massive database leak where Leo and I and hundreds of thousands of others all discovered our full social security numbers searchable online.

This brings to mind that old adage about how to keep a secret: "Don't tell anyone." I don't plan to tell Chrome or Firefox or Safari – or even my trusted password manager – anything more about me than they really require knowing for my own convenience. And if we get to a place where we're needing to frequently provide our driver's license numbers to random websites then the Internet will have entered a whole new era.

**UK to block spoofed numbers**

It's not often that I'm envious of life in the UK. Not that there's anything wrong with the UK. It's kind of hard to beat Southern California. But this next bit of news would certainly be welcomed by our UK-based listeners, and I wouldn't mind having some of it myself to go along with Southern California's sunshine. Last Wednesday the official gov.uk website posted this update under the headline *"Spoofed numbers blocked in crackdown on scammers"*. They wrote:

> *Scammers hiding behind fake numbers will be unmasked under a new partnership with Britain's biggest phone companies to protect the public from fraud.*
>
> *A landmark new agreement between government and industry, signed at the BT Tower today, will see a raft of new measures to safeguard the UK's mobile network from fraud. It will make it harder than ever for criminals to trick people through scam calls, using cutting edge technology to expose fraudsters and bring them to justice.*
>
> *Scam calls and texts are a daily frustration for many, with criminals based abroad often impersonating trusted organisations like banks and government departments to deceive people to steal money or personal information.*
>
> *Britain's six largest mobile networks have committed to upgrade their network within the next year to eliminate the ability for foreign call centres to spoof UK numbers, making it clear that calls are originating from abroad – exposing scammers lies. Data shows that 96% of mobile users decide whether to answer a call based on the number displayed on their screen, with three-quarters unlikely to pick up if it's from an unknown international number.*
>
> *Advanced call tracing technology will also be rolled out across mobile networks to give police the intelligence to track down scammers operating across the country and dismantle their operations. New commitments to boost data sharing with the police will shine a light on the mobile networks that let scam calls slip through the net, empowering customers and making it harder for scams to go undetected.*

In this regard I could easily wish that the US would be as proactive as the UK. When you think about it, this is such a simple solution. Simply examine the telephone calls entering the UK. Just watch your national borders. It's trivial to know when a call coming in from outside the UK is carrying a spoofed originating UK phone number. UK citizens travelling abroad who actually do have valid UK phone numbers will need to be admitted, but the agreement specifically talked about foreign call centers, so presumably there's some way to handle them separately.

**XSLT support is being removed from web browsers**
Something that makes a lot of sense is pruning old and aging technologies from our web browsers. Browser bloat is a very real thing. Not every idea that the Internet community comes up with gains or maintains a solid foothold. But unless proactive measures are taken to deliberately scrape the dead bits out of our browsers, they won't just go away on their own. And the last thing anyone wants is to have "zombie code" taking up space and polluting browsers with old, unmaintained and potentially exploitable code.

So it was in that spirit that Google recently announced the planned deprecation and total removal of a feature that, hopefully, no one listening is using and needs. And if you or your enterprise do, you have at most one year to replace it with some other solution because it's going away. And I should mention that moving to Firefox or Safari probably won't help because both of them are hopeful that Google will succeed.

So what's going away? Something that I suspect matters so little that most people listening have never even heard of it. It's called XSLT which is the official abbreviation for "Extensible Stylesheet Language Transformations." XSLT is a declarative template-based language that's used for transforming convenient-to-code-but-difficult-to-view XML formatted data into other forms, such as HTML. Here's what Mozilla posted about this back in August:

> *Our position is that it would be good for the long-term health of the web platform and good for user security to remove XSLT, and we support Chromium's effort to find out if it would be web compatible to remove support. If it turns out that it's not possible to remove support, then we think browsers should make an effort to improve the fundamental security properties of XSLT even at the cost of performance.*
>
> *While it's important to not break existing web content, it's also important to prevent security vulnerabilities. XSLT has been in maintenance mode in browsers and has been an ongoing source of security issues. Features and technology are sometimes removed from browsers for this reason, even when doing so breaks some existing content. Examples include Mutation Events, window.showModalDialog(), keygen, plugins. The usage of XSLT is lower than that of Mutation Events at the time of their removal, and Flash was very commonly used.*
>
> *If it turns out not to be possible to remove the feature, we'd like to replace our current implementation. The main requirements would be compatibility with existing web content, addressing memory safety security issues, and not regressing performance on non-XSLT content. We've seen some interest in sandboxing LIBXSLT, and if something with that shape satisfied our normal production requirements we would ship it.*

Wednesday before last, Google's Chrome group posted the headline *"Removing XSLT for a more secure browser"* and wrote:

> *Chrome intends to deprecate and remove XSLT from the browser. This document details how you can migrate your code before the removal in late-2026. Chromium has officially deprecated XSLT, including the XSLTProcessor JavaScript API and the XML stylesheet processing instruction. We intend to remove support from version 155 (November 17, 2026). The Firefox and WebKit projects have also indicated plans to remove XSLT from their browser engines. This document provides some history and context, explains how we are removing XSLT to make Chrome safer, and provides a path for migrating before these features are removed from the browser.*

Google then provides a timeline for this removal where, starting next March, they cautiously tiptoe forward, disabling by default (but not yet fully removing) increasing portions of Chrome's XSLT support. But the more interesting part of this event – since I really hope that no one cares about the loss of XSLT itself – is what we learn about the feature and code support evolution of the web through the lens of this event.

Here's what Google shared about the past and present of XSLT, since we now pretty much know its future. They wrote:

*XSLT was recommended by the World Wide Web Consortium (W3C) on November 16, 1999, as a language for transforming XML documents into other formats, most commonly HTML for display in web browsers. Before the official 1.0 recommendation, Microsoft took an early initiative by shipping a proprietary implementation based on a W3C working draft in Internet Explorer 5.0, released in March 1999. Following the official standard, Mozilla implemented native XSLT 1.0 support in Netscape 6 in late 2000. Other major browsers, including Safari, Opera, and later Chrome, also incorporated native XSLT 1.0 processors, making client-side XML-to-HTML transformations a viable web technology in the early 2000s.*

*The XSLT language itself continued to evolve, with the release of XSLT 2.0 in 2007 and XSLT 3.0 in 2017. These updates introduced powerful features like regular expressions, improved data types, and the ability to process JSON. Browser support, however, never followed. Today, all major web browser engines only provide native support for the original XSLT 1.0 from 1999.*

*This lack of advancement, coupled with the rise of the use of JSON as a wire format, and JavaScript libraries and frameworks (like jQuery, React, and Vue.js) that offer more flexible and powerful Document Object Model manipulation and templating, has led to a significant decline in the use of client-side XSLT. Its role within the web browser has been largely superseded by these JavaScript-based technologies.*

*So why does XSLT need to be removed?*

*The continued inclusion of XSLT 1.0 in web browsers presents a significant and unnecessary security risk. The underlying libraries that process these transformations, such as LIBXSLT (used by Chromium browsers), are complex, aging C/C++ codebases. This type of code is notoriously susceptible to memory safety vulnerabilities like buffer overflows, which can lead to arbitrary code execution. For example, security audits and bug trackers have repeatedly identified high-severity vulnerabilities in these parsers (e.g., CVE-2025-7425 and CVE-2022-22834, both in LIBXSLT).*

*Because client-side XSLT is now a niche, rarely-used feature, these libraries receive far less maintenance and security scrutiny than core JavaScript engines, yet they represent a direct, potent attack surface for processing untrusted web content. Indeed, XSLT is the source of several recent high-profile security exploits that continue to put browser users at risk. The security risks of maintaining this brittle, legacy functionality far outweighs its limited modern utility.*

*Furthermore, the original purpose of client-side XSLT—transforming data into renderable HTML—has been superseded by safer, more ergonomic, and better-maintained JavaScript APIs. Modern web development relies on things like the Fetch API to retrieve data (typically JSON) and the DOMParser API to safely parse XML or HTML strings into a DOM structure within the browser's secure JavaScript sandbox. Frameworks like React, Vue, and Svelte then*

*manage the rendering of this data efficiently and securely. This modern toolchain is actively developed, benefits from the massive security investment in JavaScript engines, and is what virtually all web developers use today. Indeed, only about 0.02% of web page loads today actually use XSLT at all, with less than 0.001% using XSLT processing instructions.*

It sure sounds like they're doing an awful lot of apologizing for something that really just needs to die. On the other hand, even the end of the horrific FLASH plugin, which took forever, was painful. And it's true that for those vanishingly rare websites that built around XSLT and will stop functioning without it, XSLT's complete disappearance from the web could prove to be a significant inconvenience. So Google continued apologizing, writing:

*This is not a Chrome or Chromium-only action: the other two major browser engines also support the removal of XSLT from the web platform: WebKit, Gecko.*

*For these reasons, deprecating and removing XSLT reduce the browser's attack surface for all users, simplify the web platform, and allow engineering resources to be focused on securing the technologies that actually power the modern web, with no practical loss of capability for developers.*

So this is a perfect textbook example of the way all of this should work. The web ecosystem needs to evolve to meet the evolving uses to which our web browsers are being put. But evolution doesn't only mean continually tacking on new feature after new feature without end. It necessarily also means trimming off the dead limbs so that the organism as whole can remain as healthy as possible.

This is never an easy thing to do because someone somewhere is going to see their website die through no fault of theirs. They will have been early adopters of an interesting technology that all browsers at the time built in and have supported ever since. Unfortunately, their use of that technology has left them being such a miniscule minority of the world that the sane decision on the part of the web browsers is to discontinue their support and to say they're sincerely sorry, which Google clearly is. If XSLT could be left in there, without compromising all Internet users, it would be left alone. But this old code which still requires maintenance sees so little use that it makes much more sense to just remove it than it does to expose everyone to its dangers that require continual repair.

**Introducing early access for Firefox Support for Organizations**

While we're on the subject of web browsers, which we'll be looking at again for today's main topic, I wanted to share Mozilla's posting last Friday which carried the headline *"Introducing early access for Firefox Support for Organizations"* The pointer to this announcement described it as "Paid Firefox support for corporate customers" which made me curious. Mozilla explained:

*Increasingly, businesses, schools, and government institutions deploy Firefox at scale for security, resilience, and data sovereignty. Organizations have fine-grained administrative and orchestration control of the browser's behavior using policies with Firefox and the Extended Support Release (ESR). Today, we're opening early access to* ***Firefox Support for Organizations****, a new program that begins operation in January 2026.*

*What* ***Firefox Support for Organizations*** *offers:*

***Support for Organizations*** *is a dedicated offering for teams who need private issue triage and escalation, defined response times, custom development options, and close collaboration with Mozilla's engineering and product teams.*

- *Private support channel accesses a dedicated support system where you can open private help tickets directly with expert support engineers. Issues are triaged by severity level, with defined response times and clear escalation paths to ensure timely resolution.*
- *Discounts on custom development: Paid support customers get discounts on custom development work for integration projects, compatibility testing, or environment-specific needs. With custom development as a paid add-on to support plans, Firefox can adapt with your infrastructure and third-party updates.*
- *Strategic collaboration: Gain early insight into upcoming development and help shape the Firefox Enterprise roadmap through direct collaboration with Mozilla's team.*

***Support for Organizations*** *adds a new layer of help for teams and businesses that need confidential, reliable, and customized levels of support. All Firefox users will continue to have full access to existing public resources including documentation, the knowledge base, and community forums, and we'll keep improving those for everyone in future. Support plans will help us better serve users who rely on Firefox for business-critical and sensitive operations.*

*If these levels of support are interesting for your organization, get in touch using our inquiry form and we'll get back to you with more information.*

To me, this sounds a bit like the result of a brainstorming meeting whose goal was to cook up new sources of revenue for Mozilla to support Firefox. But I can also easily imagine that there has probably been some true demand for these services for which Mozilla had no such program. So organizations that wish to be able to depend upon Firefox and Mozilla will now have a way of being assured that they can do so, and pay for the privilege. I dropped a link to this announcement into the show notes for anyone who's interested. That blog posting contains links to follow up: https://blog.mozilla.org/en/firefox/firefox-support-for-organizations/

**Russia continues to distance itself from the rest of the Internet**

Meanwhile, Russia's policy implementations continue to starve their own citizens of Western services. Now Akamai has reported service disruptions in Russia after the Russian government started filtering Akamai traffic. This has led to disruptions for some Russian Akamai customers. Akamai says it is aware of the government's actions, but that it's unable to do anything about it. This may just be Russia issuing a "were serious about this" warning since a full blanket block has not yet been implemented. As we've noted before, Russia now requires foreign cloud providers to open local offices in the country and register with the state.

**Google receives the OK to purchase Wiz**

A number of times in the past year we've looked at the fine security work of a company called "Wiz" – W. I. Z. as in Wizard. Another security firm, Mandiant, was once independent and we often covered their work. Then they were purchased by Google to become a division of the every-growing Google behemoth. Similarly, I wanted to note that Google's $32 billion dollar acquisition of Wiz Security recently passed US regulatory approval. Although some other jurisdictions await approval, it appears certain that Wiz will join Mandiant as Google properties.

***"Do Not Cookie!"***
Believe it or not, a recently obtained leaked copy of proposed changes to the EU's comically horrific GDPR regulation, which forced all websites everywhere to constantly request their visitor's cookie preferences will finally change the requirements to work the way they always should have.

The new regulations allow web browser users to configure their browsers ***once and for all*** to subsequently transmit their cookie, tracking and marketing preferences to every website they visit. This would be some formalized variation of the DNT / DoNotTrack header or the GPC Glogal Privacy Control signal header. And the regulations also legally require every website to silently comply with and obey any such preference transmission. Once adopted, and following a six-month implementation grace period, these amended requirements would be backed by the full weight, force and effect of the EU's GDPR — which forced those cookie pop-ups on the entire world in the first place. So the constantly annoying cookie request banners would finally disappear and users who care would be able to "set and forget" their preference in their browsers once and for all.

**Moving from Microsoft**
Last week also saw another pair of migrations away from dependence upon Microsoft's closed proprietary solutions: The International Criminal Court has dropped its use of Microsoft Office in favor of OpenDesk. This move was made in response to the US sanctioning some of its judges. Also, Austria's Armed Forces abandoned Office for LibreOffice, while the Austrian Ministry of Economy has also moved from Microsoft to NextCloud.

**More Chinese bus examinations**
Recall that last week we noted that officials in Oslo, Norway became worried about the hidden and undocumented cellular radios they found throughout their Chinese made electric buses. So out of an abundance of caution they pulled the SIM chips out of them all. I just wanted to follow up this week by noting that Norway's discovery has shaken assumptions so that investigations are now underway in several other countries, including Australia, Denmark, the UK, and the Netherlands.

**Microsoft's "Whisper Leak" attack**
Microsoft's claim in the introduction of what they named their "Whisper Leak" attack brought me up short because what it was claiming to do seemed far from plausible. They wrote:

> *Microsoft has discovered a new type of side-channel attack on remote language models. This type of side-channel attack could allow a cyberattacker a position to observe your network traffic to conclude language model conversation topics, despite being end-to-end encrypted via Transport Layer Security (TLS). We have worked with multiple vendors to get the risk mitigated, as well as made sure Microsoft-owned language model frameworks are protected.*

Okay... what?!?! Microsoft is saying that some sort of side-channel attack on a fully encrypted TLS connection can reveal LLM conversation topics? Then they tell us why we should care, writing:

> *In the last couple of years, AI-powered chatbots have rapidly become an integral part of our daily lives, assisting with everything from answering questions and generating content to*

*coding and personal productivity. As these AI systems continue to evolve, they are increasingly used in sensitive contexts, including healthcare, legal advice, and personal conversations. This makes it crucial to ensure that the data exchanged between humans and language models remains anonymous and secure. Without strong privacy protections, users may be targeted or hesitate to share information, limiting the chatbot's usefulness and raising ethical concerns. Implementing robust anonymization techniques, encryption, and strict data retention policies is essential to trust and safeguarding user privacy in an era where AI-powered interactions are becoming the norm.*

*In this blog post, we present a novel side-channel attack against streaming-mode language models that uses network packet sizes and timings. This puts the privacy of user and enterprise communications with chatbots at risk despite end-to-end encryption.*

It cannot determine what we're saying. But it appears to be able to determine if the discussion is about a specific topic. So this is certainly more than nothing. I'll let them finish:

*Cyberattackers in a position to observe the encrypted traffic (for example, a nation-state actor at the internet service provider layer, someone on the local network, or someone connected to the same Wi-Fi router) could use this cyberattack to infer if the user's prompt is on a specific topic. This especially poses real-world risks to users by oppressive governments where they may be targeting topics such as protesting, banned material, election process, or journalism. Finally, we discuss mitigations implemented by cloud providers of language models to reduce the privacy attack risks against their users. Through this process, we have successfully worked with multiple vendors to get these privacy issues addressed.*

Microsoft's post next reminds us that packet length depends upon packet content. Less content means smaller packets. And also that the ciphertext that's encrypted into plaintext will have the same approximate length as the plaintext it encrypts.

Next, we have the fact that users of cloud-based AI prefer watching the AI generating and sending tokens of text as they are generated, sequentially. As if the AI was busily typing it on its end. This means that rather than waiting to receive the entire output at once, the AI models are deliberately dribbling it out as it's being determined. That also means that the TLS protocol is similarly "dribbling out" individual encrypted packets one by one as they are being sent to the user, containing, in many cases, individual encrypted words.

And, finally, the timing of the individual dribbles contains some information about what the model went through in order to produce that next token.

And it turns out that Microsoft did, indeed, discover and implement a successful side-channel attack – without ever having any access to the encrypted content – but using the individual sizes and timing of the individual TLS packets.

This attack does not allow an eavesdropper to broadly determine what's being discussed. But, in the example they gave, they pretrained their own system with 100 examples of LLM prompt regarding money laundering. They asked about money laundering 100 different ways. And they trained their recognizer on the LLM's replies only by examining the individual TLS packet timings and lengths that replies about "money laundering" generated.

And it worked. Once they had set everything up, they allowed their system to monitor the individual packet lengths and timings of 10,000 separate conversations and 100% of the time it

successfully identified the one conversation out of 10,000 that was about money laundering. Microsoft summed the threat up as follows:

> *For many of the tested models, a cyberattacker could achieve 100% precision (all conversations it flags as related to the target topic are correct) while still catching 5-50% of target conversations. In plain terms: nearly every conversation the cyberattacker flags as suspicious would actually be about the sensitive topic—no false alarms. This level of accuracy means a cyberattacker could operate with high confidence, knowing they're not wasting resources on false positives.*
>
> *To put this in perspective: if a government agency or internet service provider were monitoring traffic to a popular AI chatbot, they could reliably identify users asking questions about specific sensitive topics—whether that's money laundering, political dissent, or other monitored subjects—even though all the traffic is encrypted.*
>
> *Important caveat: these precision estimates are projections based on our test data and are inherently limited by the volume and diversity of our collected data. Real-world performance would depend on actual traffic patterns, but the results strongly suggest this is a practical threat, not just a theoretical one.*

This seems academically interesting but not something that we would need to worry about. But then we recall Bruce Schneier's reminder: "Attacks never get weaker, they only ever get stronger." So what looks like a curiosity today has the tendency to mature over time.

So how to fix this? They wrote:

> *We have engaged in responsible disclosures with affected vendors and are pleased to report successful collaboration in implementing mitigations. Notably, OpenAI, Mistral, Microsoft, and xAI have deployed protections at the time of writing. This industry-wide response demonstrates the commitment to user privacy across the AI ecosystem.*
>
> *OpenAI, and later mirrored by Microsoft Azure, implemented an additional field in the streaming responses under key "obfuscation," where a random sequence of text of variable length is added to each response. This notably masks the length of each token, and we observed it mitigates the cyberattack effectiveness substantially. We have directly verified that Microsoft Azure's mitigation successfully reduces attack effectiveness to levels we consider no longer a practical risk.*

So a surprising side-channel attack – and, by the way, a perfect classic example of a side-channel attack – where the data being leaked is never seen, but some indirect consequences of the specific data are observable and can allow an attacker to infer what that data must have been.

## SpinRite

**David Wright**

*Hi Steve, I've bought numerous copies of Spinrite over the years, to support you, but I've never actually needed to use it in anger, I've had problems over the years, but they all turned out to have other causes.*

*Until last week. My predecessor set up a NAS for the documentation for our Measuring and Control department (installation and programming of the PLCs and associated technology.) Their documentation "drive" (it was connected by iSCSI to a server) disappeared. Looking at the NAS, one of the drives was blinking red. Checking the NAS UI, the drive was also showing a fault there, but… He who shall not be named had set up the NAS, which was the main storage for all the department's documentation, with drive-spanning zero-redundancy RAID 0!*

*I grabbed my copy of Spinrite, a USB drive adapter and plugged it in. 24 hours later the drive was back in its NAS and we were busily copying their documentation over to our NAS. A new drive has been ordered and I will be completely rebuilding their NAS with RAID 5!*

*With so much kit, it was one of those pieces that hadn't been checked since I took over, but, it being a NAS with 4 large drives in RAID, you assume the person setting it up wasn't so idiotic as to use RAID 0! Needless to say, once the dust has settled and I have time to breathe, I'll be putting in an order for another corporate license. Best regards, David Wright*

I wanted to share David's story since it's a perfect contemporary example of SpinRite 6.1 still coming to the rescue of those who need it. With a RAID configured so that any one of its four drives having problems would endanger the entire storage volume, I'm unsure what someone would do if not for SpinRite. There are many data recovery specialist services, and if a drive has failed electrically or mechanically, so that it requires a PC board swap or, god help you, a head replacement, there may be no alternative. But that sort of catastrophe is exceedingly rare. Usually they'll have a drive for a week or more of downtime, and charge several thousand dollars. They take advantage of people's desperation to have their data back. And we've heard many times from the ex-employees of these services that the first thing those companies do is run SpinRite over the drive themselves. So, many days and dollars can usually be saved, as David here just reported he did, by giving SpinRite a try yourself.

## The DNS Benchmark

While I'm on the topic of GRC software I'll mention that Saturday evening I dropped the 62nd development release of our forthcoming commercial DNS Benchmark. And I am so pleased with the way it has come out. As is so often the case when I begin one of these journeys, I only ever have some rough idea of what the end result will be. This is one reason I learned long ago – actually with SpinRite 3.1 – to never guess when it will be.

In this case, as we know, I mostly set out with the goal of adding the three newer protocols that the freeware Benchmark doesn't support: IPv6, DNS over TLS and DNS over HTTPS. But what we have wound up with after a year of work is a far more advanced and enhanced result. It now does things like quickly and automatically "sidelining" resolvers right from the get go, which it determines will be unable to compete. This allows it to spend its time accurately measuring the

performance of the DNS resolvers at the head of the pack rather than wasting time on the stragglers at the end. This behavior can be tuned since there are also several new expert-level knobs that can be turned.

Through statistical analysis of the spread of timing results, we also learned that a single pass, timing 150 queries made of the top 50 domains, which is what the freeware version has always done, was unable to yield sufficient certainty due to packet timing variations. It's easy to obtain averages, but it's surprising to see how many queries must be made to obtain 95% statistical certainty. So the new version benchmark makes 5 passes by default, though that can be set to any number. And if someone wished to measure, collect and process timing data over a much larger time span, say like two days, the Benchmark's speed can be set so that a run that would have required 30 minutes will now take 50 hours with each resolver queried 750 times. And it's still possible to perform a complete rough benchmark in 3 minutes.

There are many more features and I am very pleased with the outcome of this past year's work. While the gang in GRC's dns.dev newsgroup is pounding on the latest code, looking for anything we've all missed before the first commercial release, I'll be updating the website documentation and creating the long list of new features that have been added to the new edition.

## GRC Gmail Spam

While we're on the subject of GRC projects, recall that about a month ago near the start of October, all of GRC's weekly Security Now! Podcast email suddenly routed into Gmail's spam folders. I was horrified because I had done nothing different but suddenly Gmail was apparently thinking that all of the email GRC was originating was junk. We soon learned from our listeners that Google had apparently suffered some sort of internal glitch because many other people's email bound for Gmail which had never ever had trouble was suddenly hitting their recipient's spam folders. So it wasn't anything I was doing, nor really anything Google was doing deliberately.

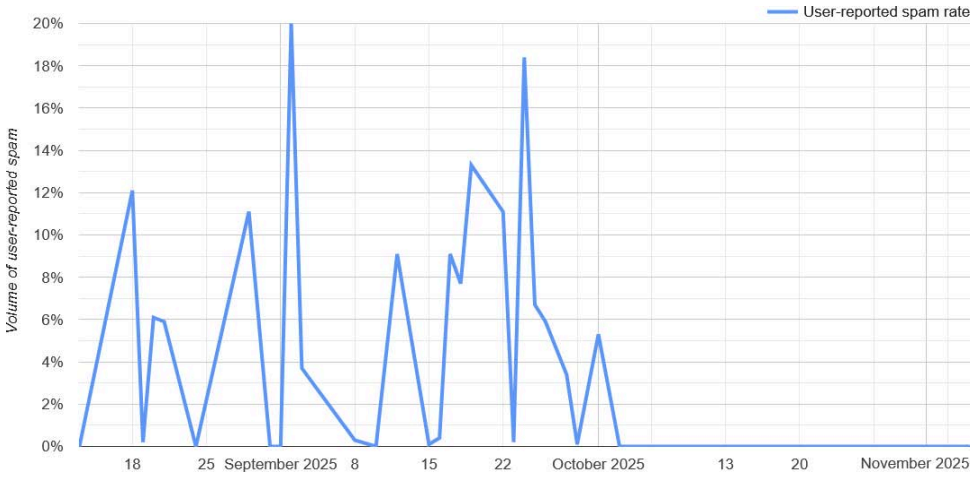
But since I am planning GRC's second-ever full list mass mailing to our more than 150,000 subscribers once the commercial version of the new DNS Benchmark is ready, the possibility that the (many) Gmail recipients among those 150,000 might get routed into spam scared the you-know-what out of me.

So, even though I was certain I had originally done all that, I returned my focus to GRC's SPF, DKIM and DMARC DNS records. All the various test sites said that everything was hunky dory, that the records restricting the spoofing of email from GRC were all correct. Yet a look at Google's user-reported spam records and chart from GRC told a very different story. Users could not be annoyed and reporting spam if none was getting into their inboxes. So Google must be admitting some.

What I discovered was that even though my anti-spam DNS records were well locked down, two optional parameters were missing from our DMARC DNS. The bits that were missing are named "alignment modes" and they can be either "relaxed" or "strict". What I discovered was that if neither is specified they default to "relaxed".

Apparently "relaxed" can also be thought of as "none" because I had SPF, DKIM and DMARC records which all of the specifications and various testing sites were saying were great. But spam was leaking through and into Google. So I added to additional terms to GRC's DMARC record: **adkim=s; aspf=s;** Alignment mode for DKIM and alignment mode for SPF. And I set both to "strict" alignment enforcement.

I haven't mentioned anything for more than the past month, though I've been checking-in with Google every few days. I now have more than that month of history and I can share the following Google chart:




This pretty clearly and convincingly shows that once DNS had propagated and Gmail updated its own internal caches – which I noticed took a week or more – the incidents of user-reported spam were squashed to a flat line at zero. So the lesson here for any of our listeners who are running their own email servers – and I know there are many because I've heard from many of you previously – once you're sure that you have everything working with SPF and DKIM, be sure at all adkim=s; and aspf=s parameters to your DMARC DNS record. Without them being explicit DMARC appears to shrug its shoulders and allow stuff through.

v=DMARC1; p=reject; sp=reject; adkim=s; aspf=s; pct=100

# Amazon sues Perplexity

Some time ago we examined /robots.txt files which were originally provided by sites as an aid to help keep web search spiders out of trouble. Controversy arose when Cloudflare decided to become much more proactive on behalf of their users when they believed robot AI agents, whether scraping for content or browsing on behalf of their users, were being deliberately deceptive and were also deliberately disobeying the clearly expressed wishes of their users.

Then, last week's podcast titled *"Here Come the AI Browsers"* looked at the vulnerabilities that could arise when AI browsers encountered remote website content which it might confuse for user instructions.

So today we have a third aspect of the AI <-> web browser amalgam, which is AI browsers acting on the Internet on behalf of their users. The Guardian's headline read *"Amazon sues AI startup over browser's automated shopping and buying feature"* which it follows with the tease: *"Amazon accuses Perplexity of covertly accessing customer accounts and disguising AI activity as human browsing."* The idea that Perplexity almost certainly does this is not news. Although questions were raised over Cloudflare's possible misinterpretation of Perplexity's automated agent actions, as a web technology developer, I was left with no questions. It seemed obvious to me that the evidence revealed deliberate shenanigans on Perplexity's part. So let's see what The Guardian's reporting adds to this. They wrote:

> *Amazon sued a prominent artificial intelligence startup Tuesday over a shopping feature in the company's browser, which can automate placing orders for users. Amazon accused Perplexity AI of covertly accessing customer accounts and disguising AI activity as human browsing.*

Okay. "Duh!" It's called "The Internet" and Amazon has done quite well thanks to the Internet. In fact, they only exist because of the Internet. So what's wrong with having a browser working on our behalf? ***THAT is the real question*** we're going to examine today. The Guardian continues:

> *Amazon's lawyers wrote: "Perplexity's misconduct must end. Perplexity is not allowed to go where it has been expressly told it cannot; that Perplexity's trespass involves code rather than a lockpick makes it no less unlawful."*

Ah! *"Expressly told it cannot"* certainly sounds as though someone has been caught ignoring and bypassing those pesky /robots.txt files ... again. But this time we don't have some bridge tollgate analogy. This time we're talking about the content owner becoming very upset. The Guardian continues:

> *Perplexity, which has grown rapidly amid the boom in AI assistants, has previously rejected the US shopping company's claims, accusing Amazon of using its market dominance to stifle competition. Perplexity wrote in a blogpost: "Bullying is when large corporations use legal threats and intimidation to block innovation and make life worse for people."*
>
> *The clash highlights an emerging debate over regulation of the growing use of AI agents, autonomous digital secretaries powered by AI, and their interaction with websites. In the suit, Amazon accused Perplexity of covertly accessing private Amazon customer accounts through its Comet browser and associated AI agent and of disguising automated activity as human*

*browsing. Perplexity's system posed security risks to customer data, Amazon alleged, and the startup had ignored repeated requests to stop. Amazon said: "Rather than be transparent, Perplexity has purposely configured its CometAI software to not identify the Comet AI agent's activities in the Amazon Store."*

Hmmm. Imagine that!

*In the complaint, Amazon accused Perplexity's Comet AI agent of degrading customers' shopping experience and interfering with its ability to ensure customers who use the agent benefit from the tailored shopping experience Amazon curated over decades. Third-party apps making purchases for users should operate openly and respect businesses' decisions on whether to participate, Amazon said in an earlier statement.*

*Perplexity earlier said it had received a legal threat from Amazon demanding that it block the Comet AI agent from shopping on the platform, calling the move a broader threat to user choice and the future of AI assistants.*

*Perplexity is among many AI startups seeking to reorient the web browser around artificial intelligence, aiming to make it more autonomous and capable of handling everyday online activities, from drafting emails to completing purchases.*

*Amazon is also developing similar tools, such as "Buy For Me", which lets users shop across brands within its app, and Rufus, an AI assistant to recommend items and manage carts.*

*The AI agent on Perplexity's Comet browser acts as an assistant that can make purchases and comparisons for users. The startup said user credentials remain stored locally and never on its servers. The startup said users had the right to choose their own AI assistants, portraying Amazon's move as an attempt to protect its business model.*

*Perplexity added: "Easier shopping means more transactions and happier customers. But Amazon doesn't care, they're more interested in serving you ads."*

Oh. So is that it? Using the CometAI browser to shop is a much more pleasant experience for its user because they won't be exposed to Amazon's constant visual bullying and repeated appeals to purchase stuff? As a heavy Amazon user I am quite familiar with the need to often decline their multiple come-ons along the way to the final purchase conclusion.

This question of the "agency" of AI agents is very interesting and it's not at all cut and dried. For example, what if rather than using Perplexity's CometAI browser we used an AI Chrome browser extension to do the same thing? In that scenario we would be using an authentic Chrome browser, but an add-on AI agent would be clicking links and pressing buttons on our behalf. So Amazon is attempting to tell the world that we're unable to make our lives better and easier while purchasing stuff from ***them***? Really?

Since the entire Internet pretty much blew up over this new battle last week, and since the rights and roles of AI agents promises to be one of the crucially important issues of our near future I want to spend a bit more time on it today before we move on. TechCrunch weighed in on this with their coverage last week titled *"Amazon sends legal threats to Perplexity over agentic browsing"*. Here's what TechCrunch reported:

*Amazon has told Perplexity to get its agentic browser out of its online store, the companies both confirmed publicly on Tuesday. After warning Perplexity multiple times that Comet, its AI-powered shopping assistant, was violating Amazon's terms of service by not identifying itself as an agent, the e-commerce giant sent the AI search engine startup a sternly worded cease-and-desist letter, Perplexity wrote in a blog post titled "Bullying is not innovation."*

*Perplexity lamented in the blog post: "This week, Perplexity received an aggressive legal threat from Amazon, demanding we prohibit Comet users from using their AI assistants on Amazon. This is Amazon's first legal salvo against an AI company, and it is a threat to all internet users."*

I agree. This is important. As I noted above, the AI add-on to Chrome thought experiment demonstrates that is a question with a very soft border. Where exactly does the AI agency begin and end? TechCrunch continues:

*Perplexity's argument is that, since its agent is acting on behalf of a human user's direction, the agent automatically has the "same permissions" as the human user. The implication is that it doesn't have to identify itself as an agent.*

*Amazon's response points out that other third-party agents working at the behest of human users do identify themselves. Amazon's statement explains: "It's how others operate, including food delivery apps and the restaurants they take orders for, delivery service apps and the stores they shop from, and online travel agencies and the airlines they book tickets with for customers."*

*If Amazon is to be believed, then Perplexity could simply identify its agent and start shopping. Of course, the risk is that Amazon, which has its own shopping bot called Rufus, could block Comet — or any other third-party agentic shopper — from its site.*

*Amazon suggests as much in its statement, which also says, "We think it's fairly straightforward that third-party applications that offer to make purchases on behalf of customers from other businesses should operate openly and respect service provider decisions whether or not to participate."*

*Perplexity claims that Amazon would block the shopping bot because Amazon wants to sell advertising and product placements. Unlike human shoppers, a bot tasked with buying a new laundry basket presumably wouldn't find itself buying a more expensive one, or getting lured into buying the latest Brandon Sanderson novel and a new set of earphones (on sale!).*

*If all of this sounds a bit familiar, that's because it is. A few months ago, Cloudflare published research accusing Perplexity of scraping websites while specifically defying requests from websites blocking AI bots. Interestingly, many people came to Perplexity's defense that time, because this wasn't a clear-cut case of web crawler bad behavior. Cloudflare documented how the AI was accessing a specific public website when its user asked about that specific website. Perplexity fans argued that this is exactly what every human-operated web browser does.*

*On the other hand, Perplexity was using some questionable methods to do that accessing when a website opted out of bots, like hiding its identity. As TechCrunch reported at the time, the Cloudflare incident foreshadowed the challenges to come if the agentic world materializes as Silicon Valley predicts it will. If consumers and companies outsource their shopping, travel bookings, and restaurant reservations to bots, will it be in the best interest of websites to*

*block bots entirely? How will they allow and work with them?*

*Perplexity may be right in that Amazon is setting a precedent. As the 800-pound gorilla in e-commerce, Amazon is clearly saying that the way this should work is for an agent to identify itself and let the website decide.*

I think that what makes this such an interesting debate is that the issue is anything but black and white. What has evolved is being called "the attention economy". But the commandeering of our attention comes at a cost to us — a cost that we often have no control over and might prefer not to pay. So one reading of what is happening is that new AI agency tools are appearing which promise to return to us some of the control that's been deliberately taken away. When we visit a web page we're its captive audience. We're subjected to whatever it wishes to do to us. It's true that we could leave. Nothing is forcing us to remain. But there might be something there we want. If it would be possible to avoid the nonsense and get only what we want, that seems like a clearly pro-user thing. It's no wonder that the agent concept is appealing to people.

I believe that this is crucially important because the way this shakes out will determine the shape of our future. My feeling is that user rights will ultimately prevail and that Amazon and others will be forced to grin and bear it, much as websites have had to tolerate the presence of ad blockers.